

Information Security Policy

Category: IT | Owner: John Doe | Effective: 2023-01-01 | Next Review: 2025-03-15

PURPOSE

To establish a framework for protecting the confidentiality, integrity, and availability of information assets owned or managed by the organisation. This policy ensures compliance with applicable laws, regulations, and contractual obligations.

SCOPE

This policy applies to all employees, contractors, consultants, temporary workers, and third-party service providers who have access to the organisation's information systems, networks, or data — regardless of location or device.

ROLES & RESPONSIBILITIES

- CISO: Owns this policy, oversees implementation, and reports to the Board.
- IT Security Team: Implements technical controls and monitors compliance.
- Managers: Ensure their teams complete mandatory security training.
- All Staff: Are required to read, acknowledge, and adhere to this policy.

LIFECYCLE RULES

1. Assets are classified on acquisition (Confidential, Internal, Public).
2. Access rights are reviewed quarterly and on role change.
3. Policies are reviewed annually or after any significant security incident.
4. Retired assets undergo secure data destruction before disposal.

ACCEPTABLE USE

- Use of company systems is permitted for business purposes only.
- Personal use is limited and must not compromise system performance or security.
- Sharing credentials or using another person's account is strictly prohibited.
- Connecting personal devices to the corporate network requires prior IT approval.

COMPLIANCE & CONSEQUENCES

Non-compliance with this policy may result in disciplinary action, up to and including termination of employment. Serious breaches may be escalated to law enforcement. All incidents must be reported to the IT Security team within 24 hours of discovery.